

GRC102 – INFORMATION SECURITY GOVERNANCE

WEEK 3 PRACTICAL LABORATORY TECHGLOBAL GOVERNANCE TRANSFORMATION SIMULATION

Student Name: Zubair Sumayyah Ajike

Registration Number: C11/26/CGRCE/17596

Course: GRC102 – Information Security
Governance

Module: Module 3 – Roles and Responsibilities
in Security Governance

Week 3: 24 September 2026

EXECUTIVE SUMMARY

TechGlobal is a fast-growing technology organisation with approximately 2,500 employees across five global offices. Although its revenue and product adoption are increasing, its security governance model has not developed at the same pace. Security decisions are currently concentrated around the IT Director, business units operate inconsistently, there is no formal governance committee structure, and the CEO and Board have limited visibility into cyber risk.

The purpose of this report is to redesign TechGlobal's security governance model so that security decisions are aligned with business objectives, responsibilities are clearly defined, conflicts are appropriately managed, and significant cyber risks can be escalated from operational teams to executive management and the Board.

The proposed governance model introduces clear roles for the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR, IT and Business Unit Leaders. It also establishes an Executive Security Council, Security Governance Committee and specialised Incident Response Working Group.

The report further develops a responsibility and authority matrix, RACI matrix, cyber-risk escalation process and segregation-of-duties controls. Together, these measures provide TechGlobal with a more structured approach to security governance and accountability.

TASK 1 – GOVERNANCE ARCHITECTURE AND STAKEHOLDER MAP

Evidence Bundle 1: Governance Gap Assessment, Stakeholder Map, Organisation Chart and Consultant Justification

This evidence bundle addresses the governance weaknesses in TechGlobal's existing model, identifies the major stakeholders, presents the proposed governance structure and explains why the structure is appropriate for the organisation.

The current model is described as "security by informal decision." The IT Director is effectively acting as security owner, risk approver and operational decision-maker, while Business Unit Leaders make local security choices without formal governance structures.

1.1 Governance Gap Assessment

No.	Governance Weakness	Business / Risk Consequence
1	Security authority is concentrated with the IT Director	Excessive concentration of authority can create conflicts of interest and reduce independent oversight.
2	There is no formal security governance committee	Security, risk, investment and compliance issues may be decided without appropriate cross-functional input.
3	Business units make inconsistent security decisions	Different offices may apply different security practices, resulting in inconsistent protection.
4	Responsibilities and accountability are unclear	It may be difficult to determine who owns a risk, approves a decision or implements corrective action.
5	The Board has limited visibility into cyber risk	Material cyber risks may not receive sufficient Board-level oversight.
6	There are weak escalation paths	Important security issues may remain at operational level

		when they should receive executive attention.
7	Risk approval and operational responsibility are combined	A person responsible for operating a system may also influence whether its risks are accepted.
8	There is no reliable decision trail	TechGlobal may have difficulty demonstrating why important security decisions were made and who approved them.

Overall Governance Gap

The main weakness is the concentration of security decision-making within IT. The proposed model therefore separates:

Board Oversight → Executive Accountability → Security Governance → Enterprise Risk → Technical Implementation → Business Ownership

1.2 Stakeholder Map

The laboratory identifies the Board, CEO, CISO, CRO/Risk, Legal/Compliance, Finance, HR, IT and Business Unit Leaders as the key governance stakeholders.

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board of Directors	Very High	Risk appetite, regulatory exposure, reputation and accountability	Material cyber risks, major incidents, risk trends and assurance	Provides oversight of material cyber risk
CEO	Very High	Business growth, strategy and acceptable risk	Security posture, major risks, incidents and investment requirements	Provides executive accountability
CISO	High	Security strategy, policy and programme effectiveness	Security performance, incidents,	Leads security governance

			vulnerabilities and risk	
CRO / Risk	High	Enterprise risk integration	Risk assessments, risk acceptance and risk trends	Integrates cyber risk into enterprise risk
Legal / Compliance	High	Legal and regulatory obligations	Incidents, privacy matters, regulations and evidence	Provides legal and regulatory advice
Finance	Medium–High	Budget and financial exposure	Security costs, losses and investment requirements	Supports financial governance
HR	Medium	People governance	Employee lifecycle, awareness and conduct information	Manages people-related security controls
IT / Technology	High	Technology delivery and continuity	Security requirements, architecture and technical risks	Implements and operates technical controls
Business Unit Leaders	High business influence	Operational performance	Business-specific risks and control requirements	Own operational risks and implement controls

1.3 Security Governance Organisation Chart



1.4 Governance Reporting and Communication

The proposed structure uses the following reporting principles:

1. The **Board** provides oversight of material cyber risks.
2. The **CEO** provides executive accountability.
3. The **CISO** leads security governance and security reporting.
4. **CRO/Risk** integrates cybersecurity into enterprise risk management.
5. **IT** implements and operates technical controls.
6. **Business Unit Leaders** own business-level risks.
7. **Legal, Finance and HR** provide specialist governance support.
8. Material risks are escalated from operational teams to executive management and, where appropriate, the Board.

1.5 Consultant Justification

TechGlobal has approximately 2,500 employees across five global offices. Its size and growth make an informal security governance model increasingly difficult to manage effectively.

The proposed structure is appropriate because it distributes responsibilities across the organisation instead of placing most security authority within IT.

The CISO becomes responsible for security governance, security strategy, policy and security reporting. IT remains responsible for technical implementation and secure technology operations.

The CRO/Risk function provides enterprise risk oversight, while Legal provides regulatory and contractual advice. Finance manages the financial implications of security investment, and HR manages people-related controls.

The CEO provides executive accountability and resolves significant business-risk decisions. The Board provides oversight of material cyber risk rather than becoming involved in routine technical operations.

The Security Governance Committee provides a formal cross-functional forum where security, risk, legal, financial, people and business concerns can be considered together.

This structure allows TechGlobal to maintain consistency across its five offices while still allowing Business Units to participate in security decisions.

TASK 2 – GOVERNANCE RESPONSIBILITY AND AUTHORITY MATRIX

Evidence Bundle 2: Governance Responsibility Matrix, Role Profiles and Conflict-Resolution Note

This evidence bundle defines the purpose, responsibilities, decision authority, reporting obligations and performance indicators for the core governance roles.

2.1 Governance Responsibility Matrix

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board	Security and risk oversight	Review material cyber risk and management performance	Board-level oversight and decisions within authority	Board	Cyber-risk reporting; material risk reviews
CEO	Executive accountability	Align security with business objectives and resolve major risks	Executive-level decisions within delegated authority	Board	Security objectives; major risk decisions
CISO	Security governance leadership	Strategy, policies, reporting and security programme oversight	Security governance decisions within authority	CEO / Executive Security Council	Policy compliance; risk treatment progress
CRO / Risk	Enterprise risk integration	Risk methodology, risk acceptance and enterprise aggregation	Enterprise risk decisions within authority	CEO / Board risk oversight	Risk register quality; treatment plans
Legal	Legal and regulatory advice	Regulatory duties, contracts, privacy and notifications	Provides legal advice and interpretation	CEO / Committee	Regulatory assessments; compliance actions
Finance	Financial governance	Budget, investment and financial exposure	Financial decisions within authority	CEO / Finance leadership	Budget performance; investment tracking

HR	People governance	Awareness, employee conduct and joiner/mover/leaver controls	HR decisions within authority	CEO / Management	Awareness completion; access removal
IT	Technology delivery	Secure operation, technical controls and continuity	Technical implementation within approved requirements	CISO / Executive management	Vulnerability remediation; service availability

2.2 Role Profiles / Responsibility Cards

Board of Directors

Purpose: Provide oversight of material cyber risk.

Responsibilities:

- Review material cyber risks.
- Review significant incidents.
- Challenge management on risk treatment.
- Review cyber-risk reporting.
- Provide oversight of risk appetite.

Decision Authority: Board-level oversight and decisions requiring Board authority.

Performance Indicators:

- Frequency of cyber-risk reporting.
- Number of material risks reviewed.

CEO

Purpose: Provide executive accountability for security and business risk.

Responsibilities:

- Align security with business objectives.
- Resolve major risk decisions.
- Support security investment.
- Ensure appropriate resources.

Decision Authority: Executive-level risk and business decisions within authority.

Performance Indicators:

- Closure of major risk decisions.
- Achievement of strategic security objectives.

CISO

Purpose: Lead security governance.

Responsibilities:

- Develop security strategy.
- Maintain security policies.
- Coordinate governance activities.
- Report security risks.
- Oversee security programmes.
- Coordinate security incident governance.

Decision Authority: Security governance decisions within delegated authority.

Performance Indicators:

- Security policy compliance.
- High-risk treatment progress.

CRO / Risk

Purpose: Integrate cyber risk into enterprise risk management.

Responsibilities:

- Maintain risk methodology.
- Review cyber-risk assessments.
- Support risk acceptance.
- Aggregate cyber risk.

Performance Indicators:

- Quality of risk register.
- Percentage of risks with treatment plans.

Legal / Compliance

Purpose: Provide legal and regulatory guidance.

Responsibilities:

- Assess regulatory obligations.
- Advise on notification.
- Review privacy matters.
- Support evidence requirements.

Performance Indicators:

- Timeliness of regulatory assessments.
- Completion of compliance actions.

Finance

Purpose: Manage financial governance around security.

Responsibilities:

- Review security budgets.
- Assess financial exposure.
- Support investment prioritisation.

Performance Indicators:

- Budget variance.
- Security investment tracking.

HR

Purpose: Manage people-related security governance.

Responsibilities:

- Security awareness.
- Joiner/mover/leaver processes.
- Employee conduct.
- Disciplinary processes.

Performance Indicators:

- Awareness completion rate.

- Timeliness of access removal.

IT

Purpose: Deliver and operate technology securely.

Responsibilities:

- Implement security controls.
- Maintain technology.
- Remediate vulnerabilities.
- Support incident response.
- Maintain continuity.

Performance Indicators:

- Vulnerability remediation.
- Availability of critical services.

2.3 Conflict-Resolution Note

Conflict 1 – IT and CISO

IT may prioritise rapid technology deployment while the CISO identifies security concerns.

Resolution: IT remains responsible for implementation while the CISO provides security governance requirements. Material disagreements are escalated to the Security Governance Committee.

Conflict 2 – CISO and CRO/Risk

The CISO may consider a risk unacceptable while the business wants to accept it.

Resolution: The CISO provides the security assessment. CRO/Risk manages the enterprise risk process. Risk acceptance must be made by the appropriate authorised risk owner.

Conflict 3 – Business Unit and Security

A Business Unit may want to avoid a security requirement because it could delay a business activity.

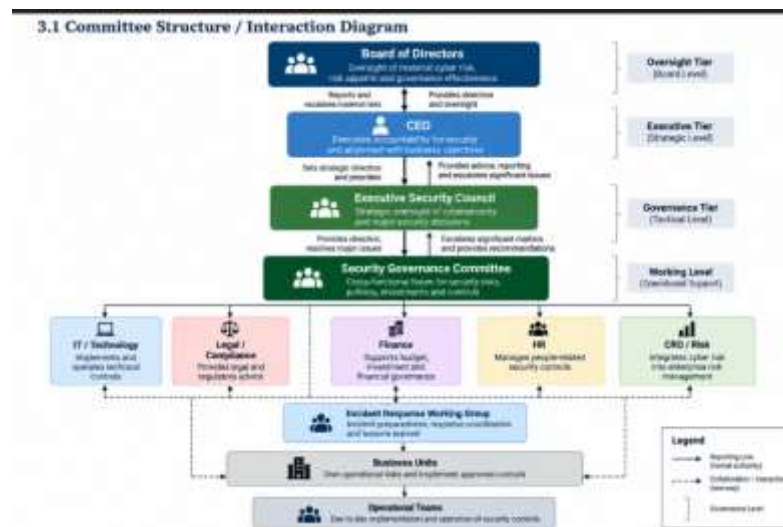
Resolution: The Business Unit presents the operational impact while the CISO presents the security implications. The issue is documented and escalated according to the established risk threshold.

TASK 3 – SECURITY GOVERNANCE COMMITTEE ECOSYSTEM

Evidence Bundle 3: Committee Structure, Terms of Reference, Agenda, Decision Log and 12-Month Governance Calendar

The laboratory requires an Executive Security Council, a Security Governance/Steering Committee and one specialised Working Group. It also requires formal decision tracking and a 12-month governance calendar.

3.1 Committee Interaction Diagram



3.2 Executive Security Council

Purpose

The Executive Security Council provides strategic oversight of cybersecurity and ensures that major security decisions align with business objectives.

Members

- CEO – Chair

- CISO
- CRO/Risk
- Finance representative
- Legal/Compliance representative
- IT leadership
- Business Unit representatives

Responsibilities

- Review material cyber risks.
- Review significant incidents.
- Review security strategy.
- Review major investments.
- Resolve major cross-functional conflicts.
- Escalate appropriate matters to the Board.

Frequency

Monthly, with emergency meetings when required.

3.3 Security Governance Committee

Purpose

The Security Governance Committee is the main cross-functional forum for security governance decisions.

Members

- CISO – Chair
- CRO/Risk
- IT
- Legal
- Finance
- HR
- Business Unit representative

Responsibilities

- Review security policies.
- Review cyber-risk assessments.
- Review security architecture.
- Review third-party security.
- Monitor access governance.
- Monitor vulnerability remediation.

- Review security awareness.
- Review business continuity matters.
- Escalate significant matters.

Frequency

Monthly.

3.4 Incident Response Working Group

Purpose

The Incident Response Working Group focuses on incident preparedness, response coordination and lessons learned.

Members

- CISO/security representative
- IT
- Legal
- HR
- Risk
- Business Unit representative

Responsibilities

- Review incident response procedures.
- Conduct incident exercises.
- Coordinate response roles.
- Review significant incidents.
- Record lessons learned.
- Recommend improvements.

3.5 Business Unit Participation

Business Units should participate through designated representatives instead of creating separate security governance structures.

Their responsibilities include:

- Reporting business-specific security risks.
- Participating in relevant governance discussions.

- Implementing approved controls.
- Escalating significant risks.
- Explaining business impacts of security decisions.

This maintains one enterprise governance model while ensuring that business requirements are considered.

3.6 Terms of Reference – Security

Governance Committee

Purpose

To provide a formal cross-functional forum for reviewing security risks, policies, investments, controls and governance decisions.

Scope

The Committee covers:

- Security strategy implementation.
- Security policies.
- Cyber-risk management.
- Security architecture.
- Third-party security.
- Access governance.
- Incident governance.
- Security awareness.
- Vulnerability remediation.
- Business continuity.

Chair

CISO.

Membership

CISO, CRO/Risk, IT, Legal, Finance, HR and Business Unit representatives.

Meeting Frequency

Monthly.

Quorum

CISO or delegate, Risk representative, IT representative and at least one other relevant governance representative.

Decision Making

Decisions are based on available evidence and recorded in the decision log.

Escalation

Issues outside the Committee's authority are escalated to the Executive Security Council.

Records

Meeting agendas, minutes, decisions, action owners and review dates are maintained.

3.7 Sample Committee Agenda

Security Governance Committee Meeting

Date: [Insert Date]

1. Opening
2. Review of previous actions
3. Cyber-risk register
4. High-risk updates
5. Security policy updates
6. Security architecture decisions
7. Third-party security
8. Access governance
9. Incident and vulnerability updates
10. Business continuity/recovery
11. Security awareness
12. Matters requiring escalation
13. New decisions
14. Action owners and deadlines
15. Any other business
16. Closing

3.8 Sample Decision Log

Date	Decision / Issue	Decision Owner	Decision	Rationale	Action / Owner	Review Date
05/10/2026	Security policy update	CISO	Approve	Existing policy requires clearer responsibilities	CISO to publish	05/01/2027
05/10/2026	High-risk third party	CISO / Risk	Escalate	Risk exceeds normal authority	Risk to prepare executive briefing	12/10/2026
05/10/2026	Vulnerability remediation delay	IT	Temporary treatment approved	Immediate remediation may disrupt critical service	IT to implement treatment	19/10/2026

3.9 12-Month Governance Calendar

Month	Governance Activity
January	Annual security strategy and risk review
February	Security policy review
March	Third-party security review
April	Security awareness review
May	Access governance review
June	Mid-year cyber-risk assessment
July	Incident response exercise
August	Security architecture review
September	Business continuity/recovery review
October	Vulnerability remediation review
November	Security budget and investment planning
December	Annual governance effectiveness review and Board reporting

Recurring Monthly Activities

- Cyber-risk review.
- Action tracking.
- Vulnerability status.
- Incident review.
- Policy exceptions.
- Third-party risks.
- Escalation review.

TASK 4 – RACI ACCOUNTABILITY MATRIX

Evidence Bundle 4: Completed TechGlobal RACI Matrix and Implementation Guide

The RACI model is designed to make accountability visible during normal operations and cyber incidents. The assignment requires coverage of 15 specified activities and asks that each activity have one clear accountable role wherever practicable.

RACI Key

R – Responsible: Performs the activity.

A – Accountable: Owns the outcome.

C – Consulted: Provides advice or input.

I – Informed: Kept informed.

4.1 Completed TechGlobal RACI Matrix

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	A	R	C	C	C	C	I	C	C
Security policy approval	I	A	R	C	C	I	C	C	C
Enterprise cyber-risk assessment	I	C	R	A	C	I	I	C	C
Risk acceptance	A	A	C	R	C	I	I	C	R*
Security budget approval	I	A	R	C	I	R	I	C	C
Security architecture approval	I	C	A	C	C	I	I	R	C
Third-party security review	I	I	A	C	C	C	I	R	R

Access governance	I	I	A	C	C	I	R	R	R
Incident response governance	I	C	A	C	C	I	C	R	C
Material incident escalation	I	A	R	C	C	I	I	R	C
Regulatory notification decision	I	A	C	C	R	I	I	C	I
Security awareness programme	I	I	A	C	C	I	R	C	R
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity / recovery governance	I	A	C	C	C	C	C	R	R
Board cyber-risk reporting	A	C	R	C	C	I	I	C	C

Note: For risk acceptance, the accountable role depends on the level of risk and delegated authority. Operational risks may remain with the appropriate Business Unit or management owner, while material risks require executive or Board-level authority.

4.2 Problematic RACI Assignments

Problem 1 – Multiple Accountable Roles

Where more than one role is shown as accountable, the final decision-maker may be unclear.

Correction: Board accountability should be limited to matters requiring Board authority. The CEO should be accountable for executive management decisions.

Problem 2 – IT Owning Broad Security Governance

If IT is made accountable for overall security governance, the organisation may recreate the current IT-centric model.

Correction: The CISO should be accountable for security governance, while IT is responsible for technical implementation.

Problem 3 – Business Units Accepting Material Risks

Business Units may understand their operations but should not accept risks beyond their authority.

Correction: Business Units manage operational risks within delegated limits. Higher risks are escalated to CISO, Risk and executive management.

4.3 RACI Implementation Guide

During Planning

Managers should identify the RACI roles before starting a security activity.

During Approval

There should be one clearly identified accountable decision-maker wherever practicable.

During Incidents

Managers should identify who:

- Owns the response.
- Makes the business decision.
- Provides legal advice.
- Provides technical support.
- Receives escalation.

During Review

The accountable person confirms that the required outcome has been achieved.

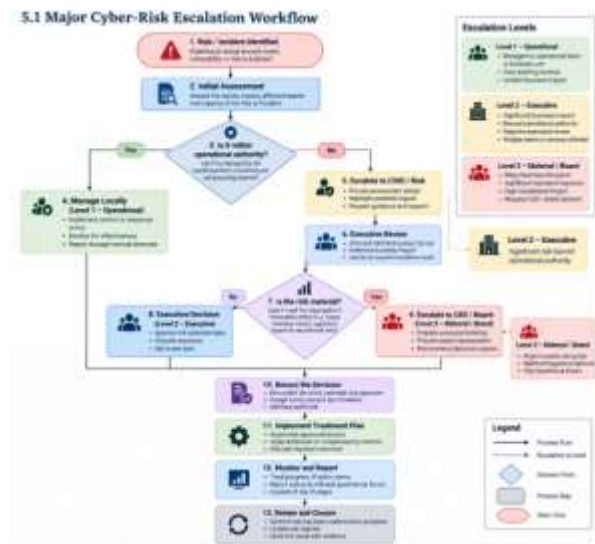
The RACI should be used as a practical decision-support tool rather than simply as a document kept for compliance purposes.

TASK 5 – CYBER-RISK ESCALATION AND SEGREGATION OF DUTIES

Evidence Bundle 5: Cyber-Risk Escalation Workflow and Threshold Table

The assignment requires a major cyber-risk escalation workflow, at least three escalation levels and defined criteria for moving risks from operational management to executive or Board decision-making.

5.1 Major Cyber-Risk Escalation Workflow



5.2 Escalation Threshold Table

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1 – Operational	Limited issue manageable using existing controls and authority	IT / Business Unit	CISO or relevant manager through normal reporting	Same business day

Level 2 – Executive	Significant risk affecting important services, multiple teams or requiring authority beyond a Business Unit	CISO / CRO/Risk / CEO as appropriate	Executive Security Council	Same day / within hours
Level 3 – Material / Board	Major incident, significant regulatory exposure, major business disruption or risk requiring Board oversight	CEO / Board according to authority	Board and relevant executives	Immediate

5.3 Escalation Criteria

A risk should move from Level 1 to Level 2 when:

- It affects multiple Business Units.
- It exceeds local decision authority.
- It could significantly affect a critical business service.
- It involves significant regulatory or contractual concerns.
- Major investment is required.
- The risk remains unresolved beyond the agreed period.

A risk should move to Level 3 when it becomes materially significant to the organisation's business, regulatory position, reputation, continuity or overall risk exposure.

Evidence Bundle 6: Segregation-of-Duties / Accountability Weakness Register and Assurance Note

The assignment requires at least five segregation-of-duties or accountability weaknesses, recommended controls and a method for maintaining an auditable decision trail.

5.4 Segregation-of-Duties / Accountability Weakness Register

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	IT Director acts as security owner, risk approver and operational decision-maker	Excessive concentration of authority	IT, CISO, Risk	Separate security governance and risk approval from technical operations	Review quarterly
2	Same person may recommend and approve risk acceptance	Risks may be accepted without sufficient challenge	IT, BU, Risk	Require independent CISO/Risk review for significant risk acceptance	Review semi-annually
3	IT implements controls and effectively assesses its own effectiveness	Independent assurance may be weak	IT, CISO	CISO/governance function reviews control effectiveness	Review quarterly
4	Business Units make local security decisions independently	Security practices may become inconsistent	BU, CISO, IT	Establish enterprise security requirements with local implementation	Review monthly

5	Incident decisions may be made without Legal or Risk input	Regulatory and business consequences may be overlooked	IT, CISO, Legal, Risk	Include Legal and Risk in significant incident escalation	Review after major incidents	
---	--	--	-----------------------	---	------------------------------	--

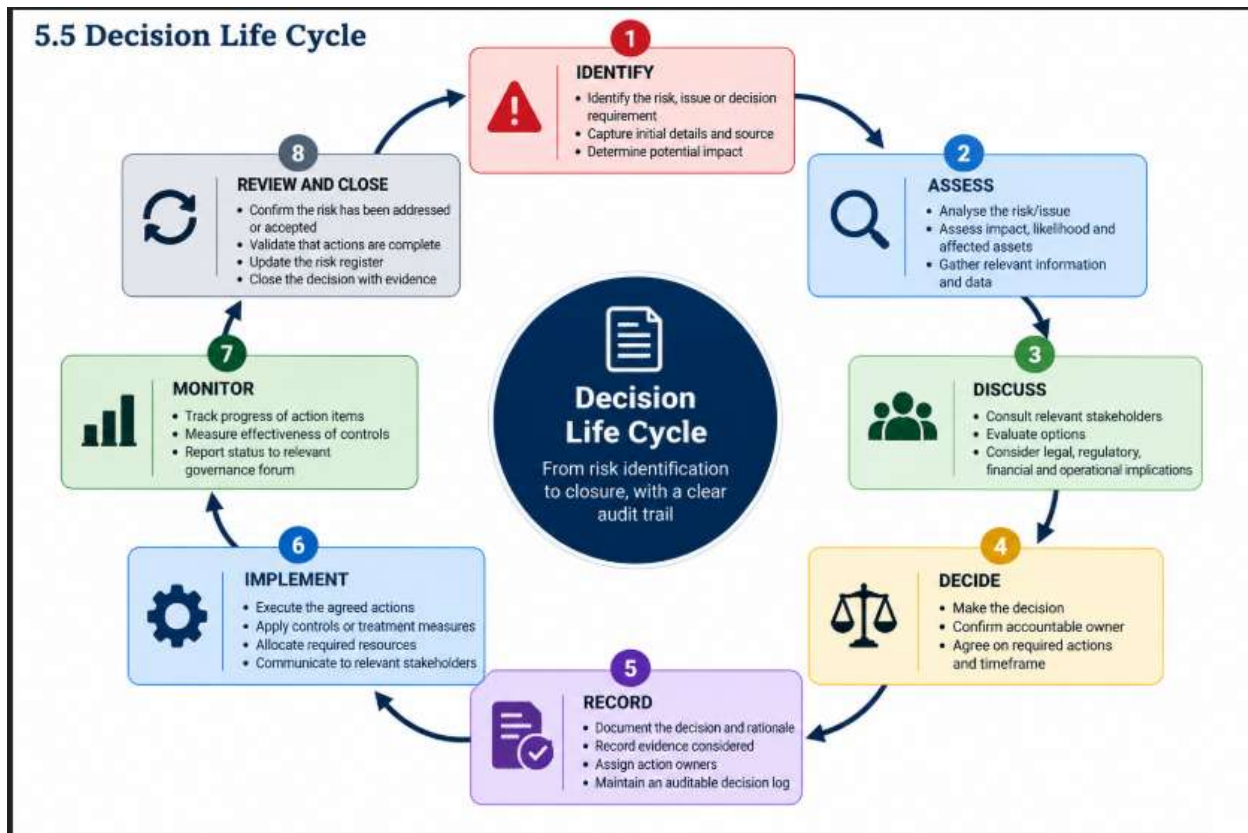
5.5 Decision-Recording and Assurance Note

Every significant security decision should be documented.

The decision record should contain:

1. Date.
2. Issue or risk.
3. Decision owner.
4. Decision.
5. Rationale.
6. Evidence considered.
7. Actions required.
8. Action owner.
9. Review date.
10. Closure status.

Decision Lifecycle

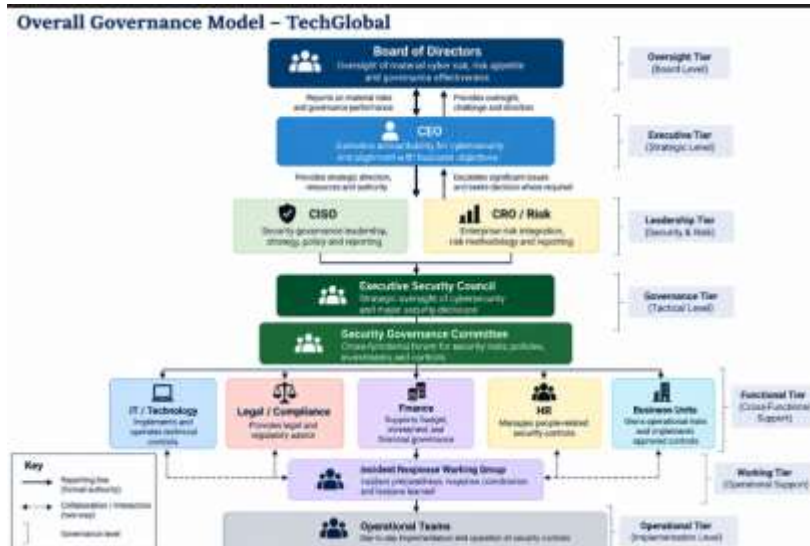


The decision log should be maintained by the appropriate governance function and reviewed during committee meetings.

This creates an auditable trail showing what happened, who made the decision, why it was made, what action was required and whether the action was completed.

OVERALL GOVERNANCE MODEL

The proposed TechGlobal governance model can be summarised as follows:



CONCLUSION

TechGlobal's current governance model is heavily concentrated around IT and does not provide sufficient separation between security ownership, risk approval and operational decision-making. The organisation also lacks formal governance committees, consistent business-unit practices and reliable escalation paths.

The proposed governance model addresses these weaknesses by establishing clear roles and decision authority across the Board, CEO, CISO, CRO/Risk, Legal, Finance, HR, IT and Business Units.

The Executive Security Council provides strategic oversight, while the Security Governance Committee provides a cross-functional forum for governance decisions. The Incident Response Working Group provides specialised operational support.

The RACI matrix makes responsibilities visible, while the risk escalation model ensures that significant issues reach the appropriate level of management. The segregation-of-duties controls reduce concentration of authority and improve independent challenge.

The proposed model therefore provides TechGlobal with a structured governance approach that supports its growth while maintaining clear accountability, appropriate escalation and visibility of material cyber risk.